Plataforma de conciencia cibersituacional

Preparación de la reunión con la tutora

Javier Saguar Antona · Grado en Ingeniería y Sistemas de Datos · ETSIT-UPM
Tutora: Carmen Sánchez-Zas (RSTI, DIT)

Noviembre de 2026 · documento de uso personal

Guía para preparar la reunión de noviembre. En la del 26 de octubre presenté la idea y el boceto del portal y el TFG quedó aceptado; ahora toca enseñar el avance, oír su opinión y cerrar las dudas de fechas y trámites. A Carmen solo le envío el resumen de una página; aquí está el detalle técnico por si pregunta, el guion y las respuestas preparadas.

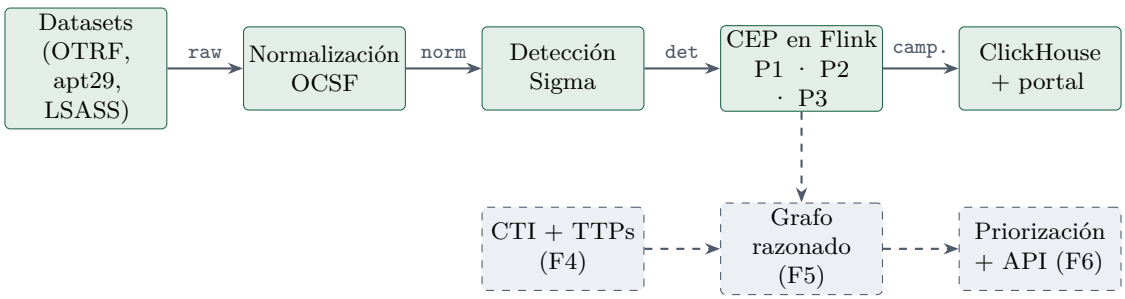
Guion de la reunión (unos 30 minutos)

1. **Contexto, 2 min.** Recordar el objetivo en una frase y el plan por fases.
2. **Avance, 10 min.** Fases 0 a 3 apoyándome en el resumen de una página. Cifras clave: 96 % de eventos normalizados, 2.093 reglas, 7 de 7 variantes de robo de credenciales, orden real de APT29 reproducido, batch y streaming idénticos.
3. **Demo del portal, 5 min** (si hay pantalla): situación, grafo del ataque, línea temporal y mapa. Llevarlo levantado: `docker compose --profile portal up -d`, en `localhost:8090`.
4. **Siguientes fases, 3 min.** F4 a F9 y la regla de recorte si en febrero no está cerrado el núcleo.
5. **Dudas, 10 min.** Título, fechas y créditos (sección 4).

El proyecto en tres líneas

Una plataforma que recibe telemetría de equipos Windows en tiempo real, la normaliza a un esquema estándar (OCSF), detecta técnicas de ataque con reglas Sigma y, sobre esas alertas, reconoce **ataques de varias etapas** con procesamiento de eventos complejos (CEP en Apache Flink). Las campañas resultantes alimentarán un grafo de ataque razonado (Pilar B) y una priorización explicable (Pilar C).

1 Arquitectura



Verde: funcionando. Gris discontinuo: siguientes fases. Las piezas se comunican por un bus de eventos (Redpanda, compatible con Kafka).

2 Lo que está hecho

2.1 Fases 0 a 2: datos, normalización y detección (cerradas en julio)

- **Infraestructura** en un solo equipo con contenedores: bus de eventos, Flink 2.2.1, ClickHouse, Prometheus y Grafana.
- **Normalización a OCSF** de unos 20 tipos de evento de Windows (Sysmon, Security, PowerShell). En el corpus de evaluación: 550.494 eventos, 530.401 normalizados (96,4 %); el resto va a una cola de errores con su motivo, nunca se descarta en silencio.
- **Detección con Sigma**: 2.093 reglas traducidas con una *pipeline* propia a OCSF. El corpus produce 1.184 alertas; el día 1 de APT29 (MITRE Evals), 741.
- **ML-1, anomalías**: Isolation Forest sobre ventanas por host, AUC-ROC 0,995 frente a 0,941 de un control que solo usa el volumen.

2.2 Fase 3: detección de ataques de varias etapas (en curso, casi cerrada)

Cada patrón se implementa dos veces: una versión de referencia en ClickHouse (SQL por lotes) y la versión en Flink con `MATCH_RECOGNIZE`, que debe reproducirla.

Patrón	Qué reconoce	Resultado
P1 Robo de credenciales	Herramienta → acceso a LSASS → volcado → limpieza	**7 de 7** variantes de volcado de LSASS (7 herramientas distintas) y 3 campañas en APT29; ratio de reducción de alertas de 0,991
P2 Movimiento lateral	Conexión a otro equipo → ejecución remota en el destino. **Cruza equipos**	La campaña SCRANTON → NASHUA (WinRM y PsExec): 17 conexiones, todas confirmadas desde los dos extremos
P3 Descubrimiento y escalada	Escalada de privilegios con descubrimiento o persistencia	3 campañas; en APT29 reproduce el orden exacto del plan del atacante (escalada → descubrimiento → persistencia)

Lo conseguido en las últimas semanas

- Los tres patrones en Flink dan **exactamente** lo mismo que su versión de referencia, también **en modo streaming** (con marcas de agua y ventanas de sesión), no solo por lotes.
- Las campañas se emiten en un **esquema común**: un hallazgo estándar OCSF «Detection Finding» con sus etapas ordenadas y la confianza descompuesta en factores explicables. Hay 15 campañas guardadas (11 de P1, 1 de P2 y 3 de P3).

2.3 Hallazgos que irán a la memoria

- **La secuencia filtra el ruido que cada señal sola no puede.** Hay mucho reconocimiento legítimo (el agente de Azure ejecuta `route`, `ipconfig` y `arp`; un script de monitorización consulta el directorio cada 15 minutos), pero sin escalada no se forma campaña.
- **La hora importa.** El conjunto APT29 trae la hora de recogida, no la del evento (hasta 101 s de desfase). Corregirla cambia el orden de los pasos: con la hora real, la conexión precede a la ejecución remota, como debe ser.
- **Límites del CEP declarativo.** Flink no puede expresar «agrupa hasta que se abra un hueco» en un solo patrón, lo que obliga a una correlación en dos niveles: el patrón reconoce cada transición y una agregación la convierte en campaña.

- **Streaming realista.** Medido el desorden de llegada de las alertas: con detección en paralelo hace falta una marca de agua de unos 5 minutos para no perder ninguna, aunque esa cifra está inflada por reproducir el corpus mucho más rápido que el tiempo real.

2.4 Extra: portal web (F8)

Un portal en React para la demostración: situación general, grafo del ataque paso a paso, línea temporal, matriz ATT&CK, incidentes, un asistente que *recomienda* (nunca ejecuta) acciones de respuesta y un mapa mundial ilustrativo. Se sirve en un contenedor. Hoy funciona con datos exportados del corpus, a la espera de la API (F6).

Para cerrar la fase 3

- Medir los **falsos positivos** sobre la parte benigna del corpus y sobre capturas de una sola táctica.
- Medir la **reducción de alertas** de los tres patrones (hoy solo está medida la de P1).
- Decidir cuánto contexto absorbe una campaña: la versión en Flink la acota a su evidencia y la de referencia absorbe ±10 minutos; afecta a la métrica de reducción.
- Validar sobre el día 2 de APT29, que aún no está cargado.

3 Siguientes fases

F4 · Inteligencia de amenazas y extracción de TTPs (dic.). Cargar ATT&CK y fuentes de CTI, y afinar un modelo pequeño de lenguaje (tipo SecureBERT) que extraiga técnicas de informes en texto libre, comparado con su versión sin afinar.

F5 · Pilar B, grafo de ataque razonado (feb.). Llevar campañas, activos y vulnerabilidades a un grafo (Neo4j) y derivar rutas de ataque con reglas Datalog; un modelo sobre el grafo propone conexiones que el razonador verifica.

F6 · Pilar C, priorización explicable (mar.). Puntuar cada incidente con factores descompuestos y explicables, ajustar los pesos con datos y exponerlo todo en una API.

F7 · Evaluación (abr.). Precisión, falsos positivos, reducción de alertas y latencia de detección, frente a líneas base sencillas y para cada componente de aprendizaje.

F8 · Portal (abr.–may.). Conectar el portal ya construido a la API real.

F9 · Despliegue, memoria y defensa (may.–jun.). Empaquetar la plataforma, cerrar la memoria y preparar la defensa.

Línea de ampliación condicionada (solo si el núcleo está cerrado el 28 de febrero): fuentes de Linux, más familias de ataque y simulaciones propias en laboratorio aislado.

4 Calendario y dudas

Fecha	Hito
30 nov. 2026	Fase 3 cerrada y fase 4 en marcha
28 feb. 2027	Núcleo defendible: fase 3 y razonamiento de la fase 5
18 mar. 2027	**Fecha límite para inscribir el TFG** (acordada el 26 de octubre; confirmar)
30 abr. 2027	Evaluación con resultados y el 60 % de la memoria
13 may. 2027	**Título definitivo** (acordado el 26 de octubre; confirmar)
15 may. 2027	Memoria completa para revisión
jun. 2027	Depósito y defensa

Memoria: la normativa de GISD parece limitar el cuerpo a 60 páginas (sin índices, resúmenes, glosario, bibliografía ni anexos). No he podido abrir el PDF oficial; conviene confirmarlo.

Dudas para la reunión (las del correo)

1. **Título provisional.** El que he planteado: *Plataforma de conciencia cibersituacional: detección de ataques multi-etapa, grafo de ataque razonado y priorización explicable de incidentes*. Preguntar si le parece adecuado, si es demasiado largo y si habrá que darlo también en inglés. Alternativas por si lo ve largo:
   - *Detección de ataques multi-etapa y priorización explicable de incidentes para la conciencia cibersituacional.*
   - *Conciencia cibersituacional en tiempo real: correlación de ataques multi-etapa y grafo de ataque razonado.*
2. **Fechas.** Confirmar las cerradas el 26 de octubre: **18 de marzo** como límite para inscribir el TFG y **13 de mayo** para el nombre definitivo. Preguntar también por el depósito y la solicitud de defensa de la convocatoria de junio.
3. **Créditos y trámites.** En el segundo cuatrimestre estoy matriculado de 33 créditos (prácticas, TFG y alguna asignatura). Para solicitar la defensa hacen falta 210 créditos superados: ¿cuándo se incorporan al expediente los créditos del segundo cuatrimestre (sobre todo las prácticas), y llegan a tiempo para defender en junio? Si no llegan, ¿la alternativa es julio? ¿Hay que pedir algo a Secretaría?

Si sobra tiempo

- **Memoria**: cuándo y cómo prefiere recibir capítulos (por ejemplo, estado del arte y diseño antes de enero).
- **Seguimiento**: una reunión al mes, ¿le encaja?
- **Prácticas de febrero a mayo**: por eso el plan cierra el núcleo en febrero. ¿Le parece realista?

Preguntas que puede hacerme y respuesta corta

¿Por qué Flink y no Spark? Flink procesa evento a evento con estado y trae `MATCH_RECOGNIZE` para secuencias; Spark trabaja en micro-lotes, con más latencia y sin CEP nativo.

¿Cómo sabes que detecta bien? Cada patrón tiene una versión de referencia en ClickHouse y la de Flink debe reproducirla exactamente. La verdad conocida sale del plan publicado de APT29 y de capturas atómicas: 7 de 7 variantes de robo de credenciales. Lo siguiente es medir los falsos positivos.

¿Por qué datos públicos y no reales? Por privacidad, por reproducibilidad y porque traen la verdad conocida. El laboratorio propio los complementa con ataques controlados.

¿Qué aporta frente a un SIEM? Correlación multi-etapa explicable, un grafo de ataque razonado y una priorización con factores descompuestos, todo abierto y reproducible en un solo equipo.

¿Dónde está el aprendizaje automático? Hay cuatro componentes: anomalías (ya hecho, AUC 0,995 frente a 0,941 del control), extracción de técnicas de informes (F4), grafo (F5) y pesos de la priorización (F6).

¿Y si no da tiempo? El núcleo mínimo es pilares A y B más la evaluación. Se recorta en este orden: pesos aprendidos, anomalías, grafo con ML y extracción de técnicas. La ampliación FA solo se hace si en febrero todo está cerrado.

¿Por qué un portal si no es el núcleo? Es el escaparate para la defensa. Va aparte y no ha frenado el pipeline.